



ОТКРЫТОЕ АКЦИОНЕРНОЕ ОБЩЕСТВО «ГАЗПРОМ»

**КОРПОРАТИВНАЯ СИСТЕМА НОРМАТИВНО-МЕТОДИЧЕСКИХ
ДОКУМЕНТОВ В ОБЛАСТИ КОМПЛЕКСНЫХ СИСТЕМ БЕЗОПАСНОСТИ
ОБЪЕКТОВ ОАО «ГАЗПРОМ»**

**СИСТЕМА ОБЕСПЕЧЕНИЯ ИНФОРМАЦИОННОЙ
БЕЗОПАСНОСТИ ОАО «ГАЗПРОМ»**

ОБЩИЕ ПОЛОЖЕНИЯ

СТО Газпром 4.2-0-003-2009

ИЗДАНИЕ ОФИЦИАЛЬНОЕ

СТАНДАРТ ОРГАНИЗАЦИИ

Москва 2009

ОТКРЫТОЕ АКЦИОНЕРНОЕ ОБЩЕСТВО «ГАЗПРОМ»

СТАНДАРТ ОРГАНИЗАЦИИ

СИСТЕМА ОБЕСПЕЧЕНИЯ ИНФОРМАЦИОННОЙ
БЕЗОПАСНОСТИ ОАО «ГАЗПРОМ»

ОБЩИЕ ПОЛОЖЕНИЯ

СТО Газпром 4.2-0-003-2009

Издание официальное

ОТКРЫТОЕ АКЦИОНЕРНОЕ ОБЩЕСТВО «ГАЗПРОМ»

Федеральное государственное учреждение
«Государственный научно-исследовательский испытательный институт
проблем технической защиты информации Федеральной службы
по техническому и экспортному контролю»

Общество с ограниченной ответственностью «Газпром экспо»

Москва 2009

Предисловие

1 РАЗРАБОТАН

Федеральным государственным учреждением
«Государственный научно-исследовательский
испытательный институт проблем технической защиты
информации Федеральной службы по техническому и
экспортному контролю»

2 ВНЕСЕН

Службой корпоративной защиты ОАО «Газпром»

3 УТВЕРЖДЕН

распоряжением ОАО «Газпром» от 11 марта 2009 г.

И ВВЕДЕН В ДЕЙСТВИЕ

№ 58

4 ВВЕДЕН ВПЕРВЫЕ

© ОАО «Газпром», 2009

© Разработка ФГУ «ГНИИИ ПТЗИ ФСТЭК России», 2008

© Оформление ООО «Газпром экспо», 2009

*Распространение настоящего стандарта осуществляется в соответствии с действующим
законодательством и с соблюдением правил, установленных ОАО «Газпром»*

Содержание

1	Область применения	1
2	Нормативные ссылки	1
3	Термины и определения.....	2
4	Основные положения	2
5	Категории и виды нормативных документов системы обеспечения информационной безопасности Общества	9
6	Организационная структура системы обеспечения информационной безопасности Общества.....	10
7	Требования к системе обеспечения информационной безопасности Общества.....	13
8	Основные методы и средства управления информационной безопасностью	14
9	Совершенствование системы обеспечения информационной безопасности	18
10	Финансирование деятельности по обеспечению информационной безопасности	20
	Библиография.....	22

СТАНДАРТ ОТКРЫТОГО АКЦИОНЕРНОГО ОБЩЕСТВА «ГАЗПРОМ»

СИСТЕМА ОБЕСПЕЧЕНИЯ ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ ОАО «ГАЗПРОМ» ОБЩИЕ ПОЛОЖЕНИЯ

Дата введения — 2009-12-28

1 Область применения

Настоящий стандарт определяет цели, задачи, функции, структуру и основные особенности построения и функционирования системы обеспечения информационной безопасности ОАО «Газпром», его дочерних обществ и организаций (далее — Общества). Требования настоящего стандарта являются основой для разработки, внедрения и эксплуатации подсистем защиты информации в автоматизированных системах управления информационными, управленческими, производственными и технологическими процессами, а также системах связи и передачи данных, используемых в деятельности Общества (далее — на объектах защиты).

2 Нормативные ссылки

В настоящем документе использованы нормативные ссылки на следующие стандарты:

СТО Газпром 4.2-3-001-2009 Система обеспечения информационной безопасности ОАО «Газпром». Руководство по разработке требований к объектам защиты

СТО Газпром 4.2-3-002-2009 Система обеспечения информационной безопасности ОАО «Газпром». Требования по технической защите информации при использовании информационных технологий

СТО Газпром 4.2-1-001-2009 Система обеспечения информационной безопасности ОАО «Газпром». Основные термины и определения

СТО Газпром 4.2-0-001-2009 Система обеспечения информационной безопасности ОАО «Газпром». Документы системы

П р и м е ч а н и е — При пользовании настоящим стандартом целесообразно проверить действие ссылочных стандартов по соответствующим указателям, составленным на 1 января текущего года, и информационным указателям, опубликованным в текущем году. Если ссылочный документ заменен (изменен), то при пользовании настоящим стандартом следует руководствоваться замененным (измененным) документом. Если ссылочный документ отменен без замены, то положение, в котором дана ссылка на него, применяется в части, не затрагивающей эту ссылку.

3 Термины и определения

В настоящем стандарте применены термины по СТО Газпром 4.2-1-001.

4 Основные положения

4.1 Целью обеспечения информационной безопасности Общества является предотвращение или существенное уменьшение возможности нанесения ущерба жизненно важным интересам Общества вследствие нарушения установленных режимов функционирования информационно-управляющих систем, деструктивного воздействия на состав и структуру информационных потоков и ресурсов.

Указанная цель достигается:

- выявлением, оценкой и прогнозированием источников угроз информационной безопасности;
- разработкой политики обеспечения информационной безопасности Общества, комплекса мероприятий и механизмов ее реализации;
- разработкой нормативной базы обеспечения информационной безопасности Общества, координацией деятельности дочерних обществ (организаций) по обеспечению информационной безопасности;
- развитием системы обеспечения информационной безопасности, совершенствованием ее организации, методов и форм предотвращения, парирования и нейтрализации угроз информационной безопасности и ликвидации последствий ее нарушения.

4.2 Задачами обеспечения информационной безопасности являются:

- создание условий для устойчивого функционирования Общества;
- создание условий, обеспечивающих установленный режим защищенности информационных массивов, баз данных и программ обработки информации, используемых в деятельности Общества;

- предотвращение утечки защищаемой информации по техническим каналам, в том числе за счет побочных электромагнитных излучений и наводок, создаваемых функционирующими техническими средствами, а также электроакустических преобразований;
- выявление возможных внедренных на объекты и в технические средства электронных устройств перехвата информации (закладных устройств) и предотвращение возможности перехвата техническими средствами речевой информации из выделенных помещений;
- предотвращение перехвата техническими и программными средствами информации, передаваемой по системам технологической связи;
- предотвращение несанкционированного доступа к обрабатываемой или хранящейся в технических средствах информации с целью ее несанкционированного уничтожения, искажения, копирования, блокирования и модификации;
- предотвращение или существенное уменьшение ущерба в результате нарушения установленных режимов функционирования информационных систем, воздействия на состав и структуру информационных потоков и ресурсов с помощью специальных программно-технических воздействий, вызывающих разрушение, уничтожение, искажение и блокирование информации или сбои в работе средств информатизации.

4.3 Решение задач обеспечения информационной безопасности Общества реализуется принятием организационных и технических мер, направленных на обеспечение защиты информации ограниченного доступа от неправомерного распространения, копирования, модифицирования, уничтожения, блокирования, а также от иных неправомерных действий в отношении такой информации.

4.4 Информация в зависимости от порядка ее предоставления или распространения в Обществе подразделяется на виды, каждому из которых соответствует свой уровень защиты (набор требований по защите):

- информация, свободно распространяемая;
- информация, обладателем которой является Общество, в том числе внутренняя информация, предназначенная для использования исключительно работниками Общества при выполнении ими своих служебных обязанностей, а также информация, содержащая сведения ограниченного доступа в соответствии с утвержденным Обществом перечнем, и т.д.;
- информация, предоставляемая по соглашению лиц, участвующих в соответствующих отношениях;
- информация, получаемая из государственных информационных систем или передаваемая в государственные информационные системы;
- информация, распространение которой в Российской Федерации ограничивается или запрещается федеральными законами.

4.5 Защита информации, получаемой из государственных информационных систем или передаваемой в государственные информационные системы, осуществляется в соответствии с требованиями, устанавливаемыми федеральным органом исполнительной власти, уполномоченным в области обеспечения информационной безопасности, и федеральным органом исполнительной власти, уполномоченным в области противодействия техническим разведкам и технической защиты информации, в пределах их полномочий.

Защита информации, распространение которой в Российской Федерации ограничивается или запрещается, осуществляется на основании соответствующих федеральных законов.

Вопросы защиты информации, содержащей указанные сведения, в настоящем стандарте не рассматриваются.

4.6 Информационные системы Общества должны быть разграничены с информационными системами и сетями других организаций, а также сетями общего пользования, включая сеть Интернет.

4.7 Решение задач обеспечения информационной безопасности Общества организуется и осуществляется в рамках специально создаваемой системы обеспечения информационной безопасности (ОИБ) Общества.

Система ОИБ Общества включает:

- совокупность взаимосвязанных структурных подразделений Общества и отдельных работников, на которых возложено решение задач ОИБ;
- систему организационно-распорядительных, нормативных, плановых и информационных документов, регламентирующих организацию и проведение работ по ОИБ Общества;
- совокупность используемых организационных и технических мероприятий, направленных на ОИБ.

4.8 Основными принципами, в соответствии с которыми строится система ОИБ Общества, являются:

- безусловное соответствие реализуемых в ней организационно-технических решений требованиям законодательства Российской Федерации, нормативным документам федеральных органов исполнительной власти, уполномоченных в сфере ОИБ, а также принципам формирования единого информационного пространства Российской Федерации;
- единство подходов к ОИБ, определению и реализации стратегии противодействия потенциальным угрозам;
- непрерывность функционирования;
- оценка достаточности принимаемых мер по ОИБ и корректировка их состава и содержания;
- адаптивность к изменяемым условиям функционирования, то есть способность к модернизации при появлении новых объектов защиты и/или новых угроз в сфере ОИБ;

- минимизация затрат на создание системы и поддержание ее в актуальном состоянии;
- адекватность системы, то есть соответствие требований по ОИБ, предъявляемых к создаваемым (модернизируемым) информационным системам, системам связи и передачами данных, реальным угрозам;
- контролируемость защитных мер, то есть применение только таких мер по ОН Б, обоснованность и эффективность которых может быть проверена;
- персональная ответственность должностных лиц за обеспечение информационной безопасности;
- доступность информационных ресурсов, услуг и сервисов;
- использование механизмов подтверждения соответствия создаваемых (модернизируемых) информационных систем, систем связи и передачи данных требованиям по ОИБ в Системе добровольной сертификации ГАЗПРОМСЕРТ [1].

4.9 Основные задачи системы ОИБ Общества

4.9.1 Участие в разработке и реализация единой политики обеспечения информационной безопасности Общества в части:

- выработки и совершенствования подходов к ОИБ Общества в интересах обеспечения бесперебойного функционирования его структур (элементов) независимо от характера угроз безопасности информации (воздействие непосредственно на информацию, на каналы связи и передачи команд управления, на физические носители информации), способа реализации этих угроз (дистанционный или контактный) и их носителей (группировки, осуществляющие противоправные действия, иностранные спецслужбы, конкуренты, собственный персонал);
- формирования системы документов, определяющих права и обязанности работников Общества по ОИБ, а также их ответственность за несоблюдение принятых в Обществе мер по ОИБ;
- разработки единой методологии организации и ведения работ по ОИБ Общества, и на ее основе — системы организационно-распорядительных и нормативных документов, определяющих принципы, порядок и особенности решения задач ОИБ;
- проведения единой технической политики Общества в области разработки, создания средств (систем) ОИБ с учетом их специфических особенностей.

4.9.2 Обеспечение проведения в Обществе работ по ОИБ на основе:

- разработки конкретных методов (способов) ОИБ с учетом недопустимости нарушения функционирования структурных подразделений Общества;
- формирования типовых сценариев организации и выполнения мероприятий по ОИБ для различных структурных подразделений Общества (добывающих, транспортирующих, перерабатывающих, управляющих) в зависимости от уровня их значимости и складывающейся обстановки на основе декомпозиции общих задач ОИБ на частные, минимизации перечня

частных задач и выработки рекомендаций по использованию конкретных средств защиты информации и технического контроля;

- проведения (в рамках существующих систем лицензирования, аттестации и сертификации) работ по обеспечению структурных подразделений Общества сертифицированными средствами защиты информации, а также по подготовке и проведению аттестации объектов защиты на соответствие требованиям безопасности информации;

- организации и осуществления информирования структурных подразделений Общества, ответственных за ОИБ, об имеющихся (прогнозируемых) угрозах безопасности, возможных путях их реализации, а также о способах их предотвращения, парирования, нейтрализации и восстановления нормального функционирования структурных подразделений Общества после устранения угрозы;

- организации подготовки специалистов по ОИБ Общества на базе соответствующих учебных заведений.

4.9.3 Обобщение требований различных структурных подразделений Общества (добывающих, транспортирующих, перерабатывающих, управляющих) к средствам защиты информации на основе типизации задач и сценариев проведения мероприятий по ОИБ с учетом необходимости обеспечения их бесперебойного функционирования.

4.10 Для обеспечения действенности системы ОИБ Общества:

- выполняется оценка деятельности структурных подразделений Общества, решающих задачи ОИБ;

- выявляются технические каналы утечки защищаемой информации и несанкционированного доступа к такой информации, в том числе возможные каналы преднамеренного деструктивного воздействия на информацию с целью ее хищения, уничтожения, блокирования или искажения:

- осуществляется анализ и оценка возможных способов несанкционированного получения информации и технической реализации способов воздействия на нее;

- выявляются нарушения установленных норм и требований по обеспечению безопасности информации;

- анализируются причины нарушений и недостатков в деятельности структурных подразделений Общества, решающих задачи ОИБ, вырабатываются рекомендации по их устранению;

- осуществляется анализ состояния ОИБ в Обществе, организуется информирование руководства Общества о состоянии дел в этой области, готовятся предложения по совершенствованию системы ОИБ;

- выполняется оценка состояния ОИБ в структурных подразделениях Общества (в том числе с использованием технических средств) с целью предупреждения и устранения нарушений установленных норм и требований.

4.11 В отношении системы ОИБ должны реализовываться процессы в соответствии с циклической моделью ПРПСР («планирование — реализация — проверка — совершенствование - планирование»).

Каждый из этапов предусматривает проведение следующих действий в отношении системы ОИБ:

- *планирования (создания системы ОИБ)* — разработки политики, целей, процессов и процедур системы ОИБ, обеспечивающих управление информационными рисками Общества, обусловленными применением информационных технологий в управленческой и производственной деятельности, а также совершенствования обеспечения информационной безопасности в интересах достижения целей Общества:

- *реализации (внедрения и эксплуатации системы ОИБ)* — внедрения и применения в структурных подразделениях Общества установленных принципов и правил обеспечения информационной безопасности, организационных и технических мер, реализуемых в рамках системы ОИБ;

- *проверки (проведения мониторинга и контроля деятельности системы ОИБ)* — проверки соответствия деятельности системы ОИБ принятым целям и действующей политике, оценки эффективности системы ОИБ и информирования руководства Общества о состоянии дел по ОИБ;

- *совершенствования (обеспечения деятельности и улучшения условий функционирования системы ОИБ)* — проведения превентивных и корректирующих действий, основанных на результатах внутреннего аудита и контроля, осуществляемых подразделениями безопасности по поручению руководства Общества с целью непрерывного совершенствования системы ОИБ.

4.12 Создание системы ОИБ Общества осуществляется на основе постоянного планирования и выполнения мероприятий, обеспечивающих реализацию установленных требований по ОИБ.

4.13 Планирование мероприятий по ОИБ состоит:

- в определении (уточнении) области действия системы ОИБ на основе результатов оценки рисков;

- разработке (уточнении) политики обеспечения информационной безопасности Общества;

- определении (уточнении) целей и задач по обеспечению информационной безопасности и мер по их реализации, обеспечивающих управление информационными рисками

Общества, обусловленными применением информационных технологий в управленческой и производственной деятельности.

4.14 Оценка рисков основывается на единой методологии, обеспечивающей получение сравнимых и воспроизводимых результатов для всех информационных технологий, используемых в управленческой и производственной деятельности Общества, и включает:

- описание методов оценки риска, применяемых к различным информационным технологиям, используемым в информационных системах Общества;
- критерии оценки рисков и нормы уровня риска для различных информационных технологий, используемых в информационных системах Общества.

4.15 Оценка информационных рисков осуществляется применительно к разрабатываемой в процессе создания ОИБ модели угроз информационной безопасности Общества, содержащей:

- классификацию объектов защиты, относящихся к области реализации системы ОИБ, их состав и принадлежность структурным подразделениям Общества;
- классификацию и состав угроз безопасности информации для объектов защиты;
- перечень уязвимостей для потенциальных угроз;
- состав возможных воздействий, которые могут привести к нарушению конфиденциальности, целостности и доступности информации, технических и программных средств ее обработки и передачи.

4.16 Величина риска подлежит постоянной переоценке и управлению в процессе реализации соответствующих организационных и технических мер, включающих:

- проведение мероприятий по выявлению угроз, уязвимостей, нарушений (инцидентов) информационной безопасности, оценке соответствия мер защиты информации различных видов и эффективности защиты информационных технологий во всех звеньях управленческой и производственной деятельности;
- обоснование уровней рисков, удовлетворяющих установленным требованиям по безопасности информации для конкретных информационных технологий, применяемых в информационных системах Общества, с разработкой соответствующих правил ликвидации последствий реализации угроз;
- внедрение и обеспечение эксплуатации средств обеспечения безопасности информации;
- перенос связанных бизнес-рисков на сторонние организации, в частности на страховщиков и поставщиков информационных технологий, применяемых в информационных системах Общества;
- постоянный контроль эффективности и совершенствование мер по ОИБ.

Меры по ОИБ определяются для структурных подразделений Общества, реализуемых процессов и применяемых информационных технологий в зависимости от установленных для них требований и уровней приемлемого риска.

Для каждого объекта защиты должен быть определен допустимый уровень риска.

4.17 Выбор (уточнение) целей, задач по обеспечению безопасности информации и реализации защитных мер и их обоснование для минимизации рисков осуществляются на основе установленной политики обеспечения информационной безопасности Общества.

4.18 Реализация (внедрение и эксплуатация системы ОИБ) заключается во внедрении и применении в структурных подразделениях Общества установленных принципов и правил обеспечения информационной безопасности, организационных и технических мер, реализуемых в рамках процессов и процедур системы ОИБ.

Внедрение и эксплуатация системы ОИБ осуществляются в соответствии с политикой обеспечения информационной безопасности информации, содержащей описание задач ОИБ и порядка применения организационных и технических мер для их решения на основании плана обеспечения информационной безопасности Общества.

В плане должен быть представлен состав процедур и мер по ОИБ и предусмотрен порядок:

- организации и обеспечения работ, связанных с реализацией системы ОИБ;
- обучения персонала по вопросам ОИБ.

4.19 Управление ресурсами системы ОИБ и реализация предусмотренных планом процедур, организационных и технических мер ОИБ осуществляются работниками подразделений безопасности Общества.

5 Категории и виды нормативных документов системы обеспечения информационной безопасности Общества

5.1 В Обществе в целях регулирования вопросов обеспечения информационной безопасности создается система нормативного обеспечения (далее - система документов), представляющая собой упорядоченную совокупность взаимосвязанных документов, регламентирующих деятельность в области обеспечения информационной безопасности.

5.2 По функционально-целевому назначению документы в области ОИБ делят:

- на организационно-распорядительные;
- нормативные;
- плановые;
- информационные.

Каждый из указанных классов документов в зависимости от вида объектов документирования подразделяют на различные категории и виды.

Структура и содержание системы документов в области ОИБ приведены в СТО Газпром 4.2-0-001.

6 Организационная структура системы обеспечения информационной безопасности Общества

6.1 Подразделение безопасности Общества, на которое возложено решение вопросов обеспечения информационной безопасности, отвечает за проведение политики обеспечения информационной безопасности Общества.

6.2 Подразделение безопасности Общества решает свои задачи путем выполнения следующих основных функций.

6.2.1 В организационной сфере:

- определение концептуальных положений по вопросам ОИБ, подготовка предложений по организации и координации работ по защите информации в структурных подразделениях Общества;

- участие в разработке и реализации мероприятий, направленных на выполнение требований нормативных документов Общества по вопросам обеспечения защиты информации;

- участие с заинтересованными структурными подразделениями Общества в разработке и реализации программ и планов ОИБ производственных, научно-исследовательских, инвестиционных и коммерческих проектов;

- разработка технических заданий на проведение в интересах Общества научно-исследовательских и опытно-конструкторских работ по созданию и внедрению систем обеспечения безопасности информации, участие в их научно-техническом сопровождении и приемке, внесение предложений в технические задания на аналогичные работы, проводимые в интересах нескольких заказчиков;

- организация работ по разработке и своевременной корректировке перечня сведений, составляющих коммерческую тайну Общества, участие в организации информационного обеспечения руководства Общества, а также подготовка нормативных документов по вопросам обеспечения защиты информации;

- содействие структурным подразделениям Общества в организации правовой охраны объектов интеллектуальной собственности.

6.2.2 В сфере разработки нормативных документов по информационной безопасности:

- разработка проектов нормативных и организационно-распорядительных документов, регламентирующих деятельность системы обеспечения информационной безопасности, а также полномочия структурных подразделений Общества и отдельных работников по вопросам обеспечения режима защиты информации и осуществлению контроля за его исполнением;

- разработка нормативного обеспечения защиты конфиденциальной информации различного характера в структурных подразделениях Общества и контроля эффективности этой защиты;

- организация разработки в Обществе стандартов организации в области обеспечения информационной безопасности.

6.2.3 В сфере обеспечения деятельности по защите информации:

- организация работ по проведению аттестации объектов информационной безопасности Общества, сертификации используемых средств и систем защиты информации по требованиям безопасности информации;

- проведение работ по аттестации защищаемых помещений на соответствие требованиям по защите информации, обследованию автоматизированных рабочих мест и слаботочного технического оборудования (системы связи, часофикации, пожарной и охранной сигнализации, системы охранного телевидения);

- организация проведения технической экспертизы и подготовка заключений на приобретаемые средства защиты информации, а также системы и средства связи и автоматизации, содержащие элементы защиты;

- анализ и подготовка экспертных заключений по вопросам обеспечения безопасности информации в разрабатываемых и внедряемых в Обществе информационных системах, системах связи и телекоммуникации;

- организация учебы по вопросам ОИБ в Обществе.

6.2.4 В сфере реализации мероприятий по ОИБ:

- разработка и реализация комплексной системы мероприятий по защите информации различной степени конфиденциальности, выявление возможных технических каналов утечки информации и потенциальных нарушителей, проведение проверок с использованием технических и аппаратно-программных средств контроля эффективности защиты информации, составляющей коммерческую тайну Общества;

- анализ информационных потоков, циркулирующих в информационных системах, систематизация информации по степени конфиденциальности, обоснование и определение на этой основе класса защищенности автоматизированных систем и средств информатизации;

- контроль и методическое обеспечение администрирования информационных систем Общества и обеспечение объективного контроля за состоянием защиты информации в целях недопущения несанкционированного доступа к защищаемой информации;

- организация и проведение работ по технической защите информации в защищаемых помещениях и средствах информатизации от утечки по техническим каналам (защита технических средств обработки информации от ее утечки по каналам побочных электромагнитных излучений, защита речевой информации от утечки по акустическим каналам).

6.3 Для реализации задач, стоящих перед системой ОИБ, в дочерних обществах (организациях) создаются подразделения безопасности и/или назначаются ответственные работники (платные и нештатные) по защите информации. Штатная численность подразделений безопасности и их структура определяются руководителями дочерних обществ (организаций).

6.4 На подразделение безопасности дочернего общества (организации) возлагаются следующие основные задачи:

- планирование работ по защите информации, предусматривающее постановку задач структурным подразделениям дочерних обществ (организаций) по решению конкретных вопросов по защите информации, организация контроля их выполнения;

- подготовка и внесение предложений в политику безопасности дочернего общества (организации);

- выбор средств управления и обеспечения безопасности информации в дочернем обществе (организации);

- контроль пользователей;

- участие в подготовке дочернего общества (организации) к аттестации и проведение аттестации на соответствие требованиям по безопасности информации;

- разработка, апробация и внедрение регламентирующих документов по защите информации в дочерних обществах (организациях);

- выявление угроз безопасности информации, связанных с возможностью ее утечки, несанкционированного доступа к ней с целью хищения, уничтожения, блокирования, изменения и реализации деструктивных воздействий, определение технических каналов утечки информации и реализации воздействий на нее и разработка соответствующих мер по ОИБ;

- разработка предложений по совершенствованию системы ОИБ, в том числе:

- при установлении и осуществлении научно-технических и торгово-экономических связей с зарубежными фирмами, а также при посещении дочерних обществ (организаций) иностранными представителями;

- при проектировании, строительстве (реконструкции) и эксплуатации объектов информационной безопасности;

- участие в согласовании заданий на проведение работ, связанных с обеспечением информационной безопасности;
- проведение периодического контроля эффективности мер защиты информации, участие в расследовании нарушений по вопросам защиты информации, имевших место в дочерних обществах (организациях), разработка предложений по устранению недостатков и их предупреждению;
- расследование событий, связанных с нарушениями безопасности информации;
- контроль восстановления работоспособности информационных систем после сбоев и аварий;
- организация проведения занятий с работниками дочерних обществ (организаций) по вопросам защиты информации.

7 Требования к системе обеспечения информационной безопасности Общества

7.1 Выполнение функций по ОИБ Общества реализуется использованием согласованной по целям, задачам, месту и порядку применения совокупности соответствующих организационных и технических мероприятий. Выполняемые в интересах ОИБ организационные и технические мероприятия и применяемые при их реализации технические и программные средства должны в минимальной степени затруднять деятельность объектов информационной безопасности и не препятствовать выполнению структурными подразделениями Общества своих функций.

7.2 Организационные мероприятия по ОИБ предусматривают установление пространственных, временных, энергетических и иных ограничений на условия использования и режимы работы объекта защиты. Организационные мероприятия должны осуществляться в координации с техническими мероприятиями.

К числу основных организационных мероприятий относятся:

- формирование системы ОИ Б Общества;
- оценка соответствия деятельности структурных подразделений Общества требованиям в области обеспечения безопасности информации;
- аттестация объектов информационной безопасности по выполнению требований обеспечения безопасности информации;
- организация разработки и внедрения информационных систем и их элементов в защищенном исполнении;

- введение частотных, территориальных, пространственных, энергетических и временных ограничений в режимах использования технических средств — потенциальных источников утечки защищаемой информации по техническим каналам;

- разработка и реализация мер по ограничению физического доступа к защищаемой информации и ее носителям, используемым при функционировании информационных систем Общества.

7.3 Технические мероприятия по ОИБ предусматривают применение технических средств и решений, обеспечивающих предотвращение или существенное затруднение утечки защищаемой информации, в том числе по техническим каналам, и реализации деструктивных воздействий на защищаемую информацию. Они могут реализовываться с использованием встроенных в объект защиты и автономных технических и программных средств.

К числу основных технических мероприятий относятся:

- применение технических средств защиты для предотвращения утечки защищаемой информации по техническим каналам;

- применение специальных средств, исключающих перехват защищаемой информации, передаваемой по каналам связи и телекоммуникаций;

- применение программных и технических средств ограничения доступа к защищаемой информации, используемой при функционировании информационных систем Общества;

- применение программных и технических средств контроля защищенности информации от утечки по техническим каналам и от деструктивных воздействий на защищаемую информацию.

7.4 Технические и программные средства защиты, используемые при работе с информационными ресурсами Общества, должны проходить проверку на соответствие требованиям по безопасности. Соответствие этих средств установленным требованиям подтверждается сертификатом, выдаваемым организацией, имеющей лицензию на этот вид деятельности, по результатам сертификационных испытаний, или предписанием на эксплуатацию, оформляемым по результатам специальных исследований и специальных проверок.

8 Основные методы и средства управления информационной безопасностью

8.1 В системе ОИБ Общества реализуются две основные функции управления:

- аналитико-прогностическая, предусматривающая прогнозирование ожидаемых изменений в состоянии объектов защиты и обстановки, в которой эти объекты функционируют, заблаговременное планирование, подготовку и организацию всестороннего обеспечения комплекса организационных и технических мероприятий по предотвращению, локализации и

нейтрализации потенциальных угроз безопасности информации и устранению возможных последствий реализации угроз;

- исполнительно-распорядительная, предусматривающая своевременное принятие мер по обеспечению безопасности информации при относительно кратковременных внезапно возникающих изменениях состояния объектов защиты, а также локализацию и устранение возникающих угроз безопасности и восстановление нормального функционирования объектов после устранения угроз.

8.2 Функционирование системы ОИБ Общества предусматривается в двух режимах: повседневном (установившемся) и оперативного управления (переходном).

8.2.1 Повседневный режим характеризуется стабильной обстановкой и состоянием объектов защиты, когда мероприятия по ОИБ этих объектов осуществляются по заранее (заблаговременно) разработанному плану, исходя из анализа тенденций развития и прогноза долговременных изменений состояния объектов, сил и средств их защиты от потенциальных угроз безопасности информации и самих угроз.

8.2.2 Режим оперативного управления характеризуется быстрым реагированием под разделений безопасности и ответственных по защите информации (как правило - с использованием программных и технических средств защиты информации) на внезапно возникающие относительно кратковременные изменения состояния объектов защиты исходя из ожидаемого (происходящего) возрастания возможностей реализации угроз безопасности информации.

8.3 Функционирование системы ОИБ в Обществе предполагает:

- обеспечение непрерывности деятельности Общества и восстановление нормального функционирования после устранения последствий нарушений безопасности информации;
- оценку соответствия принимаемых мер обеспечения информационной безопасности установленным требованиям;
- разработку, совершенствование и поддержание в актуальном состоянии системы документов, обеспечивающих функционирование системы ОИБ.

8.4 Основными формами оценки соответствия принимаемых мер по ОИБ установленным требованиям являются:

- мониторинг и контроль (надзор);
- подтверждение соответствия.

8.5 Мониторинг и контроль в системе ОИБ Общества проводятся с целью установления соответствия принимаемых мер по ОИБ установленным в Обществе требованиям по безопасности информации.

8.6 Подтверждение соответствия проводится в форме добровольной сертификации в Системе добровольной сертификации ГАЗПРОМСЕРТ [1].

8.6.1 Для средств защиты информации, сертифицированных в зарегистрированной в установленном порядке Системе обязательной сертификации средств защиты информации по требованиям безопасности информации [2], сертификация в Системе добровольной сертификации ГАЗПРОМСЕРТ может не проводиться.

8.6.2 Допускается подтверждение соответствия в форме добровольной аттестации, осуществляемой органами по аттестации, аккредитованными федеральным органом исполнительной власти, уполномоченным в области противодействия техническим разведкам и технической защиты информации.

8.7 Проведение мониторинга и контроля деятельности системы ОИБ направлено:

- на оперативное обнаружение ошибок в результатах обработки защищаемой информации;
- оперативное выявление удавшихся и неудавшихся попыток нарушения безопасности информации;
- предоставление руководству Общества возможности определения соответствия мер по обеспечению безопасности, как организационных, так и технических, установленным полномочиям и техническим требованиям;
- обнаружение событий, служащих признаками возникновения нарушений (инцидентов) информационной безопасности и позволяющих предотвращать эти нарушения (инциденты);
- оценку эффективности мер по ОИ Б для проверки выполнения установленных требований;
- пересмотр результатов оценки рисков через запланированные промежутки времени и анализ уровня остаточного и приемлемого риска с учетом изменений в организации управленческой и производственной деятельности, применяемых информационных технологиях, бизнес-целях, выявленных угрозах, изменений требований законодательства или регулирующих органов, изменений в контрактных обязательствах;
- обновление планов ОИБ с учетом результатов мониторинга и контроля;
- реагирование на действия и события, которые могли бы оказать воздействие на эффективность системы ОИБ.

8.8 В системе ОИ Б Общества должны быть реализованы:

- внутренняя оценка (проверка) состояния ОИБ;
- внешняя оценка (аудит) состояния ОИБ;
- мониторинг и контроль состояния ОИБ, включая регистрацию действий и событий, связанных с ОИБ;
- контроль эффективности защиты информации, включая анализ уровней остаточного и допустимого рисков информационной безопасности.

8.9 Оценка состояния обеспечения информационной безопасности проводится с целью осуществления объективного контроля выполнения установленных требований по обеспечению информационной безопасности в Обществе.

8.9.1 Внутренняя оценка (проверка) осуществляется самостоятельно дочерними обществами (организациями) и структурными подразделениями Общества.

8.9.2 Внешняя оценка (аудит) осуществляется независимыми специализированными организациями.

8.10 С целью оперативного обнаружения и регистрации отклонений в применении защитных мер и функционировании программно-технических средств обеспечения безопасности информации от установленных требований и оценки полноты реализации требований нормативных документов по обеспечению информационной безопасности в Обществе должен быть организован постоянный мониторинг информационной безопасности работниками подразделения безопасности.

8.11 Для целей оперативного и постоянного наблюдения за объектами защиты могут использоваться как специализированные (программные и аппаратные) средства, так и штатные (входящие в коммерческие продукты и системы) средства регистрации действий пользователей, процессов и т.п.

8.12 Контроль эффективности защиты информации осуществляется с целью определения степени соответствия возможностей системы ОИБ Общества стоящим перед ней задачам противодействия существующим угрозам.

8.13 В техническом плане объектами контроля являются средства сбора, обработки, передачи, хранения и распределения защищаемой информации в информационных системах Общества, для которых существует и может быть реализована угроза безопасности информации в виде утечки информации (по техническим каналам или вследствие несанкционированного доступа) или деструктивных воздействий на нее путем уничтожения, блокирования или искажения.

8.14 Контроль эффективности защиты информации осуществляется в процессе:

- контроля защищенности информации, обрабатываемой в информационных системах Общества;

- контроля защищенности информации, передаваемой по каналам связи.

8.15 Деятельность по контролю эффективности защиты информации не должна препятствовать нормальному функционированию структурных подразделений Общества.

8.16 Работы по контролю защищенности информации с использованием программных и технических средств должны проводиться по согласованию и при непосредственном участии представителя контролируемого объекта, отвечающего за его эксплуатацию.

Если применение средств контроля может привести к нарушению штатного режима функционирования контролируемого объекта с отягчающими последствиями, их использование запрещается. В этом случае заключение о выполнении требований по обеспечению безопасности информации должно выноситься на основе моделирования (полунатурного, математического) возможных угроз безопасности информации или на основе экспертных оценок.

При наличии на контролируемых объектах стендов, имитирующих их работу, моделирование может проводиться с использованием этих стендов, а для наиболее важных объектов - с использованием дублирующего (резервного) комплекта технических средств и программного обеспечения.

8.17 Для каждого объекта защиты должны быть запланированы мероприятия по обеспечению непрерывности его деятельности и восстановлению нормального функционирования после устранения последствий нарушения информационной безопасности,

8.18 Номенклатура и содержание предусмотренных планом мероприятий по обеспечению непрерывности деятельности объектов защиты Общества и восстановлению их нормального функционирования после устранения последствий нарушения информационной безопасности должны периодически корректироваться и своевременно обновляться (например, при существенных изменениях в содержании деятельности Общества, его организационной структуре, изменении процессов управления, модернизации информационных систем, появлении новых угроз безопасности информации).

8.19 Эффективность регламентированных процедур восстановления должна периодически проверяться и тестироваться.

8.20 В качестве методологической основы при разработке плана могут быть использованы общепринятые международные стандарты, регулирующие вопросы управления непрерывностью бизнеса.

9 Совершенствование системы обеспечения информационной безопасности

9.1 Совершенствование системы ОИБ должно осуществляться непрерывно, посредством выполнения установленных политикой обеспечения информационной безопасности Общества принципов и правил ОИБ, достижения целей ОИБ, использования результатов аудиторских проверок, анализа событий, выявленных в результате мониторинга, корректирующих и превентивных действий, а также контроля деятельности системы ОИБ, осуществляемого руководством.

9.2 Основой для принятия решений по совершенствованию системы ОИБ является анализ эффективности функционирования системы.

Анализ должен включать оценку возможных направлений совершенствования и необходимости изменений в системе ОИБ, включая изменение целей информационной безопасности, в первую очередь вследствие изменений политики обеспечения информационной безопасности Общества. Результаты таких проверок должны быть зафиксированы документально.

9.3 Анализ эффективности системы ОИБ осуществляется на основе следующей информации:

- результатов мониторинга и контроля состояния системы ОИБ;
- результатов оценок (аудита, проверок) состояния ОИБ и контроля эффективности защиты информации;
- информации об организационных мерах, программных и аппаратных средствах обеспечения безопасности информации, которые могли бы использоваться в Обществе для совершенствования функционирования и повышения эффективности системы ОИБ;
- результатов работ по предупреждению и нейтрализации угроз безопасности информации и восстановлению нормального функционирования Общества после устранения последствий нарушений безопасности информации;
- результатов анализа и оценки угроз безопасности информации, которые не были адекватно рассмотрены в процессе предыдущей оценки риска;
- результатов оценки влияния действий, предпринятых по итогам предыдущих этапов совершенствования системы ОИБ, на эффективность системы;
- общесистемных рекомендаций по совершенствованию построения и функционирования информационных систем.

9.4 По результатам анализа принимаются решения и выполняются соответствующие организационно-технические мероприятия в отношении:

- повышения эффективности системы ОИБ на основе уточненных результатов оценки информационных рисков и угроз безопасности информации;
- внесения изменений в процедуры и средства ОИБ с целью обеспечения реагирования на вновь выявленные внутренние или внешние события в информационной сфере, которые могут оказать воздействие на деятельность Общества;
- уточнения потребностей в ресурсах для обеспечения эффективного функционирования системы ОИБ;
- совершенствования методов оценки эффективности системы ОИБ;
- предотвращения повторного возникновения нарушений установленных норм и требований по обеспечению информационной безопасности.

9.5 С целью предотвращения повторного возникновения нарушений установленных норм и требований должны приниматься меры по устранению причин выявленных нарушений.

9.6 Для этого устанавливаются правила:

- выявления нарушений;
- определения причин нарушений;
- оценки необходимости проведения мероприятий по исключению возможности повторения нарушений;
- определения и реализации необходимых корректирующих действий;
- ведения учетных записей результатов предпринятых действий;
- анализа предпринятых корректирующих действий.

9.7 Меры по обеспечению информационной безопасности должны быть ориентированы как на ранее выявленные, так и на потенциально возможные нарушения. Для предотвращения потенциально возможных нарушений должны приниматься превентивные меры по ОИБ, адекватные прогнозируемым последствиям.

9.8 Процедуры по обеспечению превентивных мер по ОИБ должны включать:

- выявление потенциальных несоответствий и их причин;
- оценку необходимости принятия превентивных мер;
- обоснование и порядок реализации необходимых превентивных мер;
- ведение учетных записей результатов предпринятых превентивных мер;
- анализ эффективности предпринятых превентивных мер.

9.9 Превентивные меры по ОИБ должны соответствовать существующим рискам и требованиям, учитывающим потенциально возможные нарушения.

10 Финансирование деятельности по обеспечению информационной безопасности

10.1 Финансирование деятельности по ОИБ предусматривается в сметах расходов на деятельность Общества.

10.2 Проведение научно-исследовательских и опытно-конструкторских работ в области ОИБ, а также создание программно-технических средств и разработка документов по защите информации, не требующих капитальных вложений, осуществляются в пределах средств, выделяемых Обществом на научно-исследовательские и опытно-конструкторские работы.

10.3 Создание программно-технических средств (систем) обеспечения безопасности информации, требующих капитальных вложений, осуществляется за счет денежных средств, выделяемых Обществом на строительство (реконструкцию) объектов добычи, переработки и

транспортировки газа, а также на создание или модернизацию информационных систем, систем связи и передачами данных.

10.4 Планирование финансирования мероприятий по обеспечению безопасности информации осуществляется в установленном порядке в рамках выполнения инвестиционных проектов, имеющих в своем составе подсистемы обеспечения безопасности информации, а также по заявкам подразделений безопасности Общества.

Библиография

- [1] Система добровольной сертификации ГАЗПРОМСЕРТ РОСС RU.3022.04 ГО 00
- [2] Система сертификации средств защиты информации по требованиям безопасности информации РОСС RU.0001.01 БИ 00